Evaluación de Configuración TLS en Servicios Web

Equipo IPV6
Saira Salazar Nuñez
Hernan Rios Iglesias

Hackathon Talento Tech
RETO 2: Sistema de Análisis de Configuración TLS y Riesgo de Exposición de Servicios Web

Pereira, Risaralda
28 de marzo de 2026

Introducción

El presente documento expone el diagnóstico de seguridad efectuado sobre la dirección IPv4 34.45.64.235, suministrada por CloudLabs Learning como objeto de análisis dentro del ejercicio de auditoría.

Con el propósito de evaluar el estado de la conexión segura del servidor, se realizó una auditoría técnica orientada a revisar su configuración TLS e identificar posibles debilidades, configuraciones obsoletas o aspectos susceptibles de mejora. Para este proceso se empleó la herramienta SSL/TLS Verifier, desarrollada por el equipo, la cual permite analizar de manera automatizada parámetros relevantes de la conexión segura, como las versiones de TLS habilitadas, configuraciones detectadas y características asociadas al cifrado.

A partir de este análisis, la solución genera un informe visual automatizado que consolida los principales hallazgos y recomendaciones, facilitando su comprensión tanto para perfiles técnicos como para espacios de presentación ejecutiva.

Contexto de la empresa

CloudLabs Learning es una empresa colombiana del sector educativo dedicada al desarrollo de soluciones tecnológicas orientadas al aprendizaje práctico e inmersivo, con alcance en más de 32 países. Su modelo se basa en la aplicación del conocimiento a escenarios reales y en el diseño de experiencias caracterizadas por la simplicidad, la adaptabilidad y el enfoque de negocio. Dado que presta servicios en línea y opera en entornos digitales de alcance internacional, es indispensable que sus plataformas mantengan estándares adecuados de ciberseguridad, de forma que se preserve la confidencialidad, integridad y disponibilidad de la información, así como la protección de los procesos de autenticación y de las comunicaciones seguras entre usuarios y servicios.

Dado que CloudLabs Learning presta servicios en línea y soporta interacciones a través de plataformas digitales, resulta fundamental verificar que las comunicaciones entre los usuarios y sus servicios web se encuentren adecuadamente protegidas. En este contexto, la evaluación de TLS permite identificar si el servidor mantiene habilitadas versiones seguras del protocolo, si existen configuraciones obsoletas o débiles y si el canal de comunicación cumple con condiciones mínimas de confidencialidad, integridad y autenticidad. Este análisis es relevante no solo desde una perspectiva técnica, sino también para reducir riesgos de exposición, fortalecer la postura de seguridad del servicio y respaldar la confianza en una plataforma con alcance internacional.

Reconocimiento del servicio

Para el reconocimiento inicial del objetivo se realizó un escaneo mediante la herramienta testssl.sh, con el fin de identificar los protocolos habilitados, capacidades de cifrado y características generales de la configuración segura del servicio:

```
Testing all IPv4 addresses (port 443): 34.45.64.235
----------------------------------------------------------------------------
 Start 2026-03-28 10:06:49        -->> 34.45.64.235:443 (34.45.64.235) <<--

 rDNS (34.45.64.235):    235.64.45.34.bc.googleusercontent.com.
 Service detected:       HTTP

 Testing protocols via sockets except NPN+ALPN

 SSLv2      not offered (OK)
 SSLv3      not offered (OK)
 TLS 1      offered (deprecated)
 TLS 1.1    offered (deprecated)
 TLS 1.2    offered (OK)
 TLS 1.3    not offered and downgraded to a weaker protocol
 QUIC       not offered or timed out
 NPN/SPDY   http/1.1 (advertised)
 ALPN/HTTP2 http/1.1 (offered)

 Testing cipher categories

 NULL ciphers (no encryption)                      offered (NOT ok)
 Anonymous NULL Ciphers (no authentication)        offered (NOT ok)
 Export ciphers (w/o ADH+NULL)                     not offered (OK)
 LOW: 64 Bit + DES, RC[2,4], MD5 (w/o export)      not offered (OK)
 Triple DES Ciphers / IDEA                         not offered
 Obsoleted CBC ciphers (AES, ARIA etc.)            offered
 Strong encryption (AEAD ciphers) with no FS       offered (OK)
 Forward Secrecy strong encryption (AEAD ciphers)  offered (OK)
```

El escaneo realizado sobre la dirección IPv4 34.45.64.235 permitió identificar que el servicio analizado opera sobre el puerto 443 y corresponde a un servicio HTTP con soporte de comunicación segura. Como resultado del reconocimiento inicial, se evidenció que el servidor no ofrece los protocolos SSLv2 ni SSLv3, lo cual representa una condición adecuada desde el punto de vista de seguridad. No obstante, se observó que mantiene habilitadas las versiones TLS 1.0 y TLS 1.1, actualmente consideradas obsoletas y

desaconsejadas, mientras que TLS 1.2 se encuentra habilitada correctamente. Adicionalmente, la salida indica que TLS 1.3 no se ofrece, o bien que la conexión es degradada hacia un protocolo más débil, lo que sugiere una oportunidad de mejora en la configuración del servicio.

En cuanto a las capacidades criptográficas identificadas, se observa la presencia de NULL ciphers y de cifrados anónimos, ambos catalogados como no seguros, debido a que pueden comprometer la confidencialidad o la autenticación de la comunicación.

Análisis de las suites criptográficas soportadas

La revisión de las preferencias de cifrado del servidor evidencia que, para TLS 1.0, se encuentran habilitadas múltiples suites criptográficas con distintos niveles de seguridad. Entre ellas se observan configuraciones robustas, como aquellas basadas en AES de 256 y 128 bits con intercambio ECDHE-RSA, las cuales aportan mejores condiciones de protección al incorporar mecanismos de cifrado fuertes y, en algunos casos, propiedades asociadas a secreto hacia adelante. Sin embargo, también se identifican suites menos recomendables, incluyendo configuraciones con AES en modo CBC, uso de Camellia, así como suites anónimas y especialmente suites NULL, en las que no se aplica cifrado efectivo sobre la comunicación.

```
 Testing server's cipher preferences

Hexcode  Cipher Suite Name (OpenSSL)       KeyExch.   Encryption  Bits     Cipher Suite Name (IANA/RFC)
-----------------------------------------------------------------------------------------------------------
----------------------
SSLv2
 -
SSLv3
 -
TLSv1 (no server order, thus listed by strength)
 xc014   ECDHE-RSA-AES256-SHA               ECDH 521   AES         256      TLS_ECDHE_RSA_WITH_AES_256_C
BC_SHA
 xc019   AECDH-AES256-SHA                   ECDH 521   AES         256      TLS_ECDH_anon_WITH_AES_256_C
BC_SHA
 x35     AES256-SHA                         RSA        AES         256      TLS_RSA_WITH_AES_256_CBC_SHA

 x84     CAMELLIA256-SHA                    RSA        Camellia    256      TLS_RSA_WITH_CAMELLIA_256_CB
C_SHA
 xc013   ECDHE-RSA-AES128-SHA               ECDH 521   AES         128      TLS_ECDHE_RSA_WITH_AES_128_C
BC_SHA
 xc018   AECDH-AES128-SHA                   ECDH 521   AES         128      TLS_ECDH_anon_WITH_AES_128_C
BC_SHA
 x2f     AES128-SHA                         RSA        AES         128      TLS_RSA_WITH_AES_128_CBC_SHA

 x41     CAMELLIA128-SHA                    RSA        Camellia    128      TLS_RSA_WITH_CAMELLIA_128_CB
C_SHA
 xc010   ECDHE-RSA-NULL-SHA                 ECDH 521   None        None     TLS_ECDHE_RSA_WITH_NULL_SHA

 xc015   AECDH-NULL-SHA                     ECDH 521   None        None     TLS_ECDH_anon_WITH_NULL_SHA

 x02     NULL-SHA                           RSA        None        None     TLS_RSA_WITH_NULL_SHA
```

La presencia de suites NULL y anonymous cipher suites constituye un hallazgo crítico, ya que implica que el servidor acepta configuraciones donde la confidencialidad de la información puede verse comprometida o donde no existe una autenticación sólida del extremo remoto. Adicionalmente, el hecho de que estas suites estén disponibles bajo TLS 1.0, protocolo actualmente obsoleto, incrementa el nivel de exposición del servicio. Aunque se observa soporte para algoritmos de cifrado fuertes como AES-256 y AES-128, la

coexistencia de opciones inseguras dentro de la misma configuración refleja una política criptográfica permisiva que debe ser restringida.

Como conclusión, este resultado muestra que el servidor no solo mantiene habilitado un protocolo desaconsejado, sino que además permite la negociación de suites criptográficas inseguras o heredadas. Desde la perspectiva de seguridad, se recomienda deshabilitar TLS 1.0, eliminar las suites NULL y anónimas, y limitar la configuración únicamente a suites modernas, autenticadas y con cifrado fuerte, preferiblemente asociadas a TLS 1.2 o superior.

Análisis de parámetros criptográficos avanzados

```
 -

 Has server cipher order?     no (NOT ok)
 -- inconclusive test, matching cipher in list missing, better see above

 Testing robust forward secrecy (FS) -- omitting Null Authentication/Encryption, 3DES, RC4

 FS is offered (OK)           ECDHE-RSA-AES256-GCM-SHA384 ECDHE-RSA-AES256-SHA384 ECDHE-RSA-AES256-SHA
                              ECDHE-RSA-CHACHA20-POLY1305 ECDHE-RSA-CAMELLIA256-SHA384
                              ECDHE-ARIA256-GCM-SHA384 ECDHE-RSA-AES128-GCM-SHA256
                              ECDHE-RSA-AES128-SHA256 ECDHE-RSA-AES128-SHA
                              ECDHE-RSA-CAMELLIA128-SHA256 ECDHE-ARIA128-GCM-SHA256
 KEMs offered                 None
 Elliptic curves offered:     prime256v1 secp384r1 secp521r1 X25519 X448
 TLS 1.2 sig_algs offered:    RSA-PSS-RSAE+SHA384 RSA-PSS-RSAE+SHA256 RSA+SHA512 RSA+SHA384 RSA+SHA256
                              RSA+SHA224 RSA+SHA1

 Testing server defaults (Server Hello)

 TLS extensions               "max fragment length/#1" "EC point formats/#11"
                              "application layer protocol negotiation/#16" "encrypt-then-mac/#22"
                              "extended master secret/#23" "session ticket/#35" "next protocol/#13172"
                              "renegotiation info/#65281"
 Session Ticket RFC 5077 hint 300 seconds, session tickets keys seems to be rotated < daily
 SSL Session ID support       yes
 Session Resumption           tickets: yes, ID: no
 TLS 1.3 early data support   not offered, as no TLS 1.3 offered
 TLS clock skew               Random values, no fingerprinting possible
 Client Authentication        none
 Signature Algorithm          SHA256 with RSA
 Server key size              RSA 1024 bits (exponent is 65537)
 Server key usage             --
```

La evidencia obtenida muestra que el servidor no impone un orden propio de preferencia para las suites criptográficas, lo cual constituye una práctica no recomendada, ya que limita la capacidad del servicio para priorizar de forma estricta los algoritmos más seguros durante la negociación TLS. No obstante, se observa como aspecto favorable la presencia de Forward Secrecy, mediante el uso de suites basadas en ECDHE, lo que fortalece la protección de las sesiones al evitar que una eventual exposición de la clave privada del servidor comprometa comunicaciones pasadas.

Adicionalmente, se identifican suites criptográficas modernas como AES-GCM y CHACHA20-POLY1305, así como el soporte de curvas elípticas robustas, entre ellas X25519, X448, prime256v1 y secp384r1, lo que evidencia capacidades criptográficas adecuadas en varios componentes de la configuración. Sin embargo, persisten elementos heredados que deben ser revisados, como la aceptación del algoritmo RSA+SHA1 dentro de TLS 1.2 y la ausencia de soporte para TLS 1.3, lo que indica que el servicio aún no adopta completamente las prácticas más actuales de seguridad.

Finalmente, uno de los hallazgos más relevantes corresponde al uso de una clave RSA de 1024 bits, tamaño que actualmente se considera insuficiente frente a los estándares modernos de seguridad. En conjunto, estos resultados reflejan una configuración parcialmente robusta, pero con debilidades importantes asociadas a compatibilidad heredada y falta de endurecimiento criptográfico completo. negociar.

Reporte

Tras la ejecución de la herramienta SSL/TLS Verifier, se generó un reporte ejecutivo que consolida de manera estructurada los principales resultados obtenidos durante el análisis de la dirección IPv4 evaluada. Este informe presenta una visión resumida del estado de la configuración SSL/TLS del servidor, incluyendo los protocolos detectados, los hallazgos inseguros identificados, su nivel de severidad y las recomendaciones de remediación asociadas.

Reporte de Análisis SSL/TLS

Servidor analizado: 34.45.64.235

Estado del objetivo: OK

Detalle: Análisis completado correctamente.

Nivel de exposición general: CRITICO

Resumen ejecutivo

- Total hallazgos detectados: 14
- Críticos: 2
- Altos: 4
- Medios: 6
- Bajos: 2
- Versiones heredadas detectadas: TLS 1.0, TLS 1.1
- Versiones seguras detectadas: TLS 1.2
- Versiones recomendadas ausentes: TLS 1.3
- Postura del protocolo: Configuración heredada con soporte moderno parcial

Protocolos SSL/TLS detectados

Protocolo	Estado	Evidencia
SSLv2	DESACTIVADA	`SSLv2 not offered (OK)`
SSLv3	DESACTIVADA	`SSLv3 not offered (OK)`
TLS 1.0	ACTIVADA	`TLS 1 offered (deprecated)`
TLS 1.1	ACTIVADA	`TLS 1.1 offered (deprecated)`
TLS 1.2	ACTIVADA	`TLS 1.2 offered (OK)`
TLS 1.3	DESACTIVADA	`TLS 1.3 not offered and downgraded to a weaker protocol`

Hallazgos inseguros detectados

#	Severidad	Hallazgo	Evidencia	Recomendación
1	CRITICO	TLS 1.0 habilitado	`TLS 1 offered (deprecated)`	Deshabilitar TLS 1.0 y restringir el servicio a TLS 1.2 o superior.
2	CRITICO	TLS 1.1 habilitado	`TLS 1.1 offered (deprecated)`	Deshabilitar TLS 1.1 y restringir el servicio a TLS 1.2 o superior.
3	CRITICO	NULL ciphers habilitados	`NULL ciphers (no encryption) offered (NOT ok)`	Deshabilitar suites sin cifrado real.
4	CRITICO	Cifrados anónimos habilitados	`Anonymous NULL Ciphers (no authentication) offered (NOT ok)`	Deshabilitar suites anónimas sin autenticación.
5	ALTO	Cifrados CBC obsoletos habilitados	`Obsoleted CBC ciphers (AES, ARIA etc.) offered`	Priorizar suites AEAD modernas y reducir el uso de CBC heredado.
6	MEDIO	El servidor no define preferencia de cifrados	`Has server cipher order? no (NOT ok)`	Configurar el orden de preferencia de cifrados del lado del servidor.
7	CRITICO	SAN ausente en el certificado	`subjectAltName (SAN) missing (NOT ok) -- Browsers are complaining`	Incluir subjectAltName válido en el certificado.
8	CRITICO	El certificado no coincide con el host analizado	`Trust (hostname) certificate does not match supplied URI`	Asegurar coincidencia entre el certificado y el dominio o IP esperada.
9	CRITICO	Certificado autofirmado	`Chain of trust NOT ok (self signed)`	Reemplazar por un certificado emitido por una CA confiable.
10	ALTO	Clave RSA débil	`Server key size RSA 1024 bits (exponent is 65537)`	Migrar a una clave RSA de al menos 2048 bits.
11	MEDIO	HSTS no configurado	`Strict Transport Security not offered`	Habilitar HSTS para forzar el uso de HTTPS.
12	MEDIO	Posible exposición a BREACH por compresión HTTP	`BREACH (CVE-2013-3587) potentially NOT ok, "gzip" HTTP compression detected. - only supplied "/" tested`	Revisar el uso de compresión HTTP en respuestas con información sensible.
13	BAJO	TLS 1.3 no está habilitado	`TLS 1.3 not offered and downgraded to a weaker protocol`	Evaluar compatibilidad para habilitar TLS 1.3.
14	BAJO	Banner del servidor expuesto	`Server banner nginx/1.18.0 (Ubuntu)`	Minimizar la exposición de banners para reducir información visible.

A diferencia de las evidencias técnicas observadas en las secciones anteriores, este reporte permite integrar la información en un formato más claro y orientado a la toma de decisiones, facilitando la interpretación de los resultados tanto para perfiles técnicos como para instancias de gestión o dirección. De esta forma, no solo se identifican las debilidades presentes en la configuración del servicio, sino que también se priorizan las acciones necesarias para su fortalecimiento.

Los resultados consolidados evidencian que el servidor presenta una configuración no segura, en la que coexisten controles adecuados, como la deshabilitación de versiones antiguas de SSL, con debilidades relevantes, entre ellas la habilitación de TLS 1.0 y TLS 1.1, la presencia de suites criptográficas inseguras o heredadas, la ausencia de TLS 1.3 y otros elementos de configuración que incrementan la superficie de exposición. En consecuencia, el reporte generado constituye un insumo útil para orientar un proceso de endurecimiento criptográfico y mejora de la postura de seguridad del servicio analizado.
A diferencia de las evidencias técnicas observadas en las secciones anteriores, este reporte permite integrar la información en un formato más claro y orientado a la toma de decisiones, facilitando la interpretación de los resultados tanto para perfiles técnicos como para instancias de gestión o dirección. De esta forma, no solo se identifican las debilidades presentes en la configuración del servicio, sino que también se priorizan las acciones necesarias para su fortalecimiento.